

Coastal Logistics Co.

Scan results:

[HIGH] customer-tracking-portal - nginx Range Filter Integer Overflow (CVE-2022-41741)
[MEDIUM] fleet-tracking-svc - OpenSSH Pre-Authentication User Enumeration (CVE-2018-15473)
[MEDIUM] driver-hr-db - PostgreSQL Privilege Escalation via ALTER ... DEPENDS ON EXTENSION (CVE-2020-14349)

Register results:

[6.80] fleet-tracking-svc OpenSSH Pre-Authentication User Enumeration (CVE-2018-15473)
[6.48] customer-tracking-portal nginx Range Filter Integer Overflow (CVE-2022-41741)
[4.68] driver-hr-db PostgreSQL Privilege Escalation via ALTER ... DEPENDS ON EXTENSION (CVE-2020-14349)

Phase 4 — Threat Modeling Workshop

Finding (host / CVE)	STRIDE	Threat Description	Existing or missing control	Framework mapping
[6.80] fleet-tracking-svc OpenSSH Pre-Authentication User Enumeration (CVE-2018-15473)	I-Information Disclosure	An attacker can send specially crafted SSH authentication requests and observe differences in the server's response. It does not give the attacker the password or automatically log them in. It primarily exposes information that can help an attacker target valid accounts with later attacks.	Control: patch management, update OpenSSH to a fixed version, and restrict SSH access to trusted users/networks	TTP (an attacker can recon and try to get user accounts.)
[6.48] customer-tra	D-Denial of Service	If NGINX is configured to process MP4 files, an attacker who can cause	Control: Upgrade NGINX to a fixed version. If MP4	TTP (an attacker can cause

cking-portal nginx Range Filter Integer Overflow (CVE-2022-4 1741)		it to process a specially crafted audio/video file may be able to corrupt the memory of an NGINX worker process. This can cause the worker to terminate and potentially have other security impacts.	processing is not needed, disabling the MP4 module/functionality can also reduce the attack surface.	memory corruption, and potentially disable the system causing a DOS.)
[4.68] driver-hr-db PostgreSQL Privilege Escalation via ALTER ... DEPENDS ON EXTENSION (CVE-2020-1 4349)	T-Tamperin g	An authenticated attacker could create malicious database objects and exploit the replication process to cause arbitrary SQL commands to run with the privileges of the replication user. If that replication account had high privileges, the impact could be significant.	Control: Upgrade PostgreSQL to a patched version and limit replication privileges to only the permissions actually required.	TTP (attacker may try to use this SQL to run privileges, and modify data or database

Phase 5 — Executive Communication Deliverable

Three known security weaknesses could expose sensitive information, disrupt services, or allow unauthorized changes to business data:

1. Sensitive information could be exposed.

An attacker could potentially discover valid user accounts and use that information to target company systems and employee accounts.

Recommended action: Update the SSH software and restrict remote access to trusted users and networks. Timeline: within 5 business days.

2. Business services could be disrupted.

A specially crafted media file could cause a web server to crash, potentially making websites or applications unavailable to customers and employees.

Recommended action: Update the web server software and disable unnecessary media-processing features. Timeline: within 5 business days.

3. Critical business data could be changed without authorization.

A weakness in the database system could allow an attacker with an existing account to execute unauthorized database commands and potentially modify important company information.

Recommended action: Update the database software and review accounts with elevated database permissions. Timeline: within 5 business days.

Leaving these weaknesses unresolved increases the likelihood of account-targeting attacks, service outages, or unauthorized changes to critical data, potentially resulting in financial loss, operational disruption, and reputational damage.